



零知识证明

汪 定 教授

南开大学 密码与网络空间安全学院

2026年4月2日

一个对话

Peggy: “我知道美联储计算机的口令，可乐的秘密调味汁的成分，以及Knuth第5卷的内容。”

Victor: “不，你不知道。”

Peggy: “我知道。”

Victor: “你不知道！”

Peggy: “我确实知道！”

Victor: “请你证明这一点！”

Peggy: “好吧，我告诉你！”她悄悄地说出了美联储计算机口令。

Victor: “太有趣了！现在我也知道了。我要告诉《华盛顿邮报》。”

ATM信息泄露

许多年前，有报道称小偷在一个超市中放置假的ATM机。当人们将银行卡插入机器并输入鉴别身份的秘密（PIN码）时，机器将PIN码信息记录下来，吞卡并反馈消息说机器不能接受这种类型的银行卡。小偷接下来就可以拿到吞下的银行卡，并使用得到的PIN码信息到真的ATM机上提取现金。



提 纲

CONTENTS



1. 零知识证明概念总揽

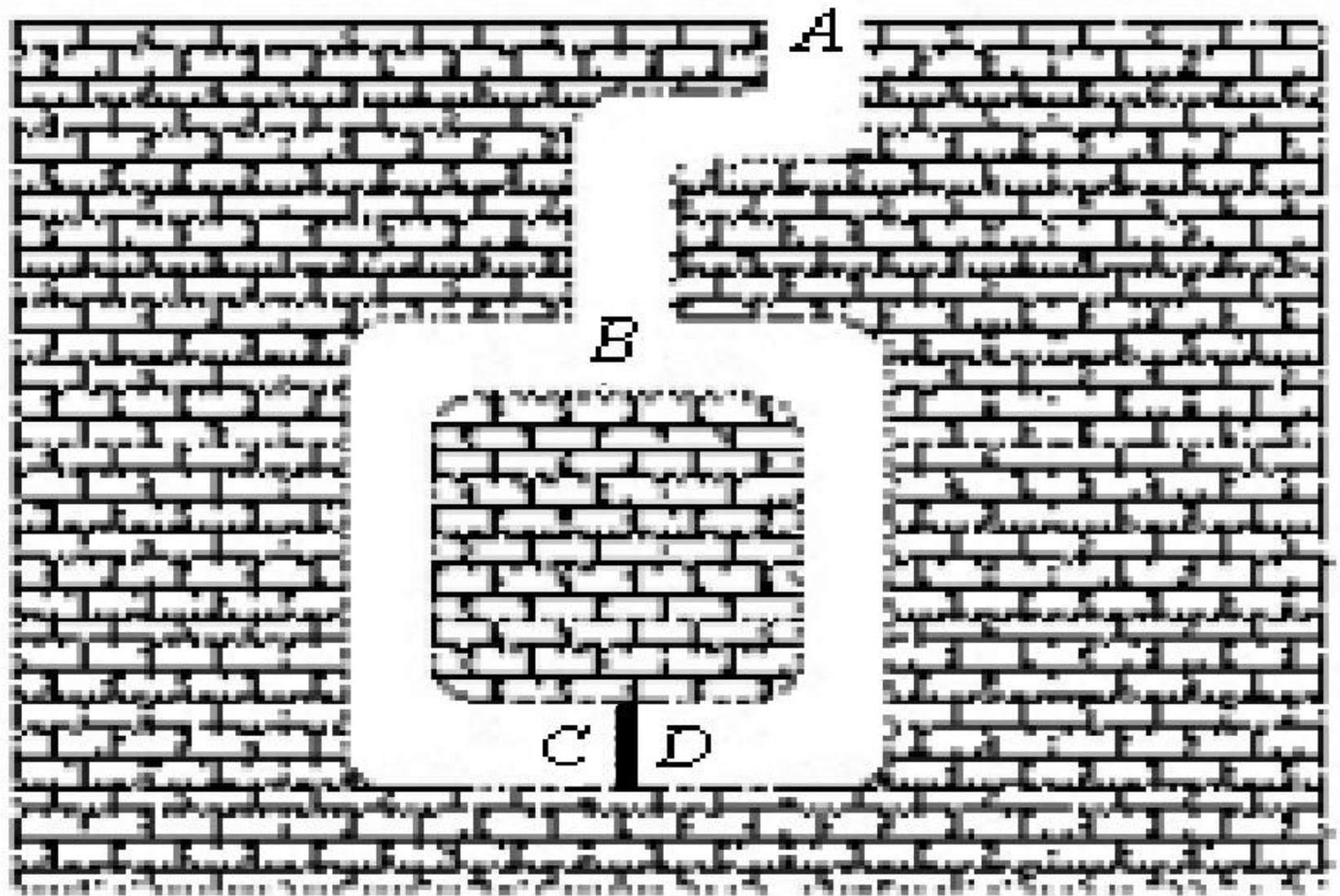
2. Fiat-Shamir鉴别协议

3. Feige-Fiat-Shamir鉴别协议

4. GQ鉴别协议

5. Schnorr鉴别协议

思想



不泄露洞穴私密的协议

Peggy知道打开洞穴的秘密。她想对Victor证明这一点，但她不想泄露咒语。下面是她如何使Victor相信的过程：

1. Victor站在A点，Peggy站在B点。
2. Peggy一直走进洞穴，到达点C或点D。
3. 在Peggy消失在洞穴中之后，Victor走到点B。
4. Victor向Peggy喊，要她：
 - 4.1 从左通道出来
 - 或者
 - 4.2 从右通道出来
5. Peggy答应了，如果有必要她就用咒语打开密门；然后，回到第1步。如此反复n次。

将东西等分的协议

□ 协议使用的技术叫做**分割选择技术**(cut and choose), 因为它类似如下将任何东西等分的经典协议:

1. Peggy将东西切成两半。
2. Victor给自己选择一半。
3. Peggy拿走剩下的一半。

注: Peggy最关心的是第1步中的等分, 因为 Victor可以在第2步选择他想要的那一半。

交互式证明系统

- ❑ 零知识证明协议是交互证明系统的一个实例，这里一个证明者和一个验证者交互多轮。
- ❑ 证明者的目标是让验证者相信其声称的正确性，例如，声称掌握一个秘密 s （比如一串01信息）。验证者要么接受证明，要么拒绝证明。
- ❑ 这与传统的数学概念的证明有所不同：交互游戏的证明是随机而不是确定性的。由于这个原因，一个交互证明常常被称为协议证明。

交互证明与知识证明

□ 用于鉴别的交互证明可以被形式化为知识证明。

证明者Prover掌握某个秘密 s ，并通过正确的回答验证者Verifier所提出的问题(涉及的是公开已知的输入和协商一致的函数), 使其相信确实掌握秘密 s 。当然，回答这些问题需要秘密 s 。

□ 一个交互证明是知识证明如果证明满足完备性和可靠性。

交互式证明系统的完备性

□ 定义1(完备性)

如果给定一个诚实的证明者和认证者，协议能以压倒性的概率获得成功(也就是，验证者接受证明者的宣称)，则称交互式证明(协议)是完备的。

确保：真的假不了

注：完备性可以看作是协议在诚实参与者执行的情况下的一般要求。对压倒性的概率的定义依赖具体应用，但通常意味着失败的概率无实际意义。

交互式证明系统的可靠性

□ 定义2 (可靠性)

一个交互证明(协议)是可靠的，不存在一个平均多项式时间算法 M 满足如下性质：

如果一个不诚实的证明者可以不可忽略的概率，成功与验证者(Verifier)执行协议，则 M 可以得到这个证明者(Prover)的知识(本质上等于Prover的秘密 s)，这使得后续 M 的协议执行将以压倒概率获得成功。

确保：假的真不了

交互式证明系统的可靠性（续）

- 由于任何有能力冒充Prover的一方都等同于知道Prover的秘密知识 s (即, 攻击者*Malice*可以在多项式时间内来计算它)。
- 可靠性这一属性保证了协议确实提供了对知识的证明: 知识等价于对询问的正确回答。
- 换句话说: 可靠性阻止了非法的证明者使诚实的验证者相信知识 s 的可能。

交互式证明系统的零知识属性

□ 定义3 (零知识属性)

一个知识证明的协议有零知识属性，仅当协议可模拟如下功能：存在一个概率多项式（PPT）算法，它可以不和真实的证明者交互，就可以生成这些证明所必须的交互消息。这些生成的消息与同真实的证明者交互产生的消息，二者不可区分。

简而言之：在交互的过程中，证明者不会泄露关于知识 s 的任何信息。

对零知识属性的评述

- ❑ 零知识属性表明一个证明者执行协议(即使与恶意验证者交互)不会泄露任何信息 (即除了要证明的断言以外): 无异于在多项式时间从公开信息中计算。
- ❑ 考虑一个观察者 C , C 观测证明者 $Alice$ 与验证者 Bob ($Bob \neq C$)执行一个零知识证明协议交互过程, 且 Bob 确定了 $Alice$ 掌握某个知识。向 Bob 证明的过程并不能给 C 任何额外有用信息。这就是零知识属性的基本思想, 即证明过程可以由验证者单独模拟完成。(事实上, $Alice$ 和 Bob 可能事先串通应答内容来欺骗 C 。)
- ❑ 零知识保证了验证者 Bob 没有计算能力把和知识 s 有关的信息抽取出来。不能抽取的知识不代表不存在。可靠性保证了知识的存在性。

零知识证明协议的一般结构

□ 一般结构

- $A \rightarrow B$: 证据
- $A \leftarrow B$: 提问
- $A \rightarrow B$: 回答



- 以上描述了一大类三次交互零知识协议的一般结构：证明者A随机选择一个在事先定义的集合上的元素做一个秘密承诺，并从中计算相关的公开证据。这提供了每一次协议执行的随机性，并限定了A在本次协议执行中所能回答问题的集合，因此，也就限定了将来的可能答案。
- 协议是一个循环执行过程，如果需要，就可以通过控制循环次数降低欺骗成功的概率。

零知识协议 vs. 非对称密码技术

- **依赖困难性假设**：零知识协议和非对称密码技术都依赖于计算困难性假设(例如，大合数因子分解的困难性，离散对数难解性)。
- **使用不退化**：协议具有零知识属性因此不会因为重复使用而降低安全性, 并可阻止选择消息攻击。这可能是零知识技术在实践中最吸引人之处。
- **无需加密**：许多零知识技术都不需要使用加密算法。
- **效率低**：虽然一些零知识基技术非常有效，但是具有零知识属性的协议通常比没有零知识属性的非对称协议需要更多通信和计算开销。更为有效的实用零知识基方案通常源于交互证明的特性，而不是它的零知识特性。

零知识协议的典型应用

- ❑ 数据的隐私保护，如保护个人隐私和商业秘密。
- ❑ 计算压缩与区块链扩容，如zkSNARK 技术。
- ❑ 端到端的通讯加密，如用户之间可以互相发消息，但是不用担心服务器拿到所有的消息记录。
- ❑ 身份认证，如用户可以向网站证明，他拥有私钥，或者知道某个只有用户自己才知道的秘密如口令，而网站并不需要知道，但是网站可以通过验证这个零知识证明，从而认证用户。
- ❑ 去中心化存储：服务器可以向用户证明他们的数据被妥善保存，并且不泄露数据的任何内容。
- ❑ 信用记录：信用记录是另一个可以充分发挥零知识证明优势的领域，用户可以有选择性的向另一方出示自己的信用记录，一方面可以有选择的出示满足对方要求的记录分数，同时证明信用记录的真实性。



提 纲

CONTENTS



1. 零知识证明概念总揽

2. 一个典型实例

3. Schnorr鉴别协议

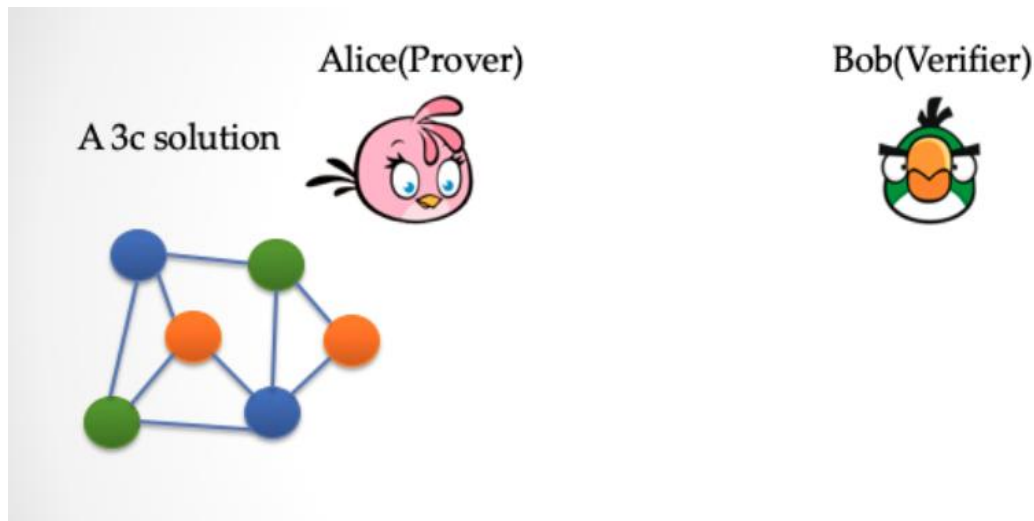
4. GQ鉴别协议

5. Schnorr鉴别协议

地图三染色问题

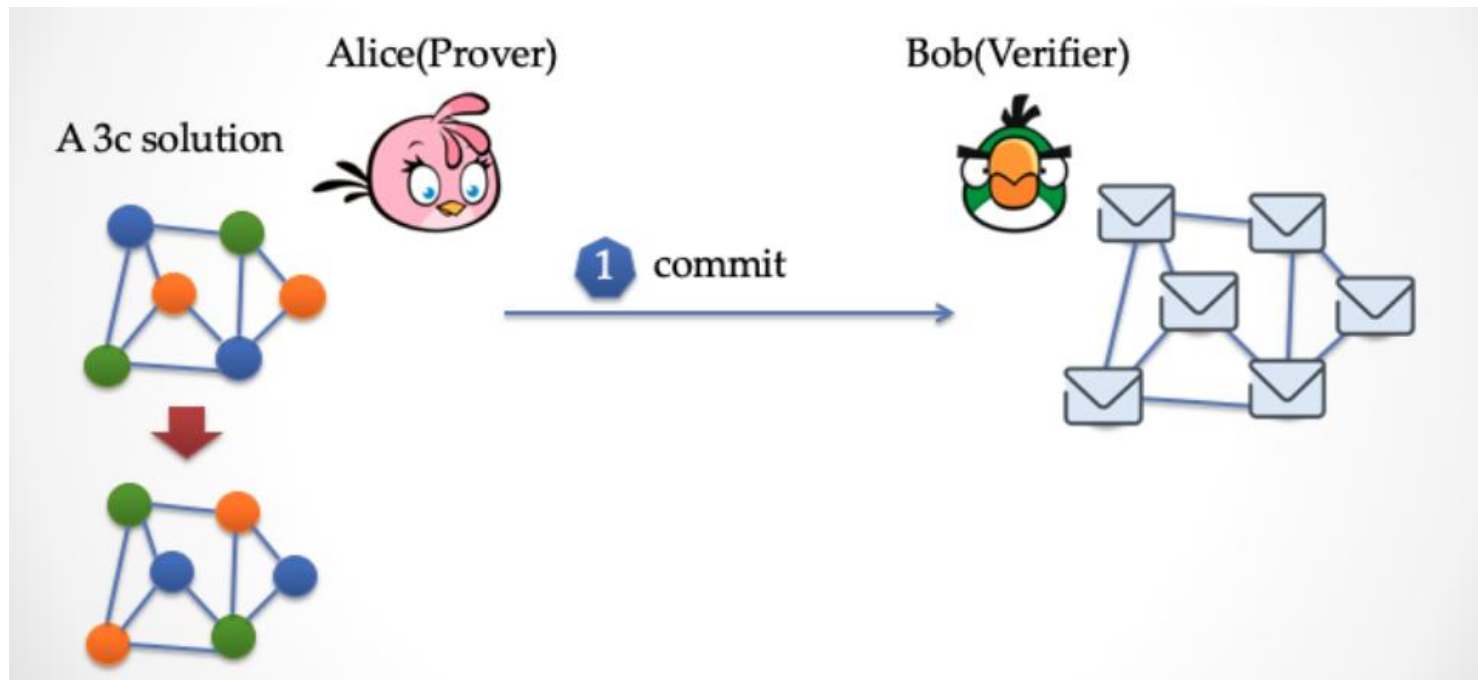
- 简述：如何用三种颜色染色一个地图，保证任意两个相邻的地区都是不同的颜色。我们把这个「地图三染色问题」转变成一个「连通图的顶点三染色问题」。假设每个地区都有一个首府（节点），然后把相邻的节点连接起来，这样地图染色问题可以变成一个连通图的顶点染色问题。
- 下面我们设计一个交互协议：
 - 证明者 Alice
 - 验证者 Bob

Alice如何才能既不泄露
染色方法，同时又能向
Bob证明她知道染色方法？



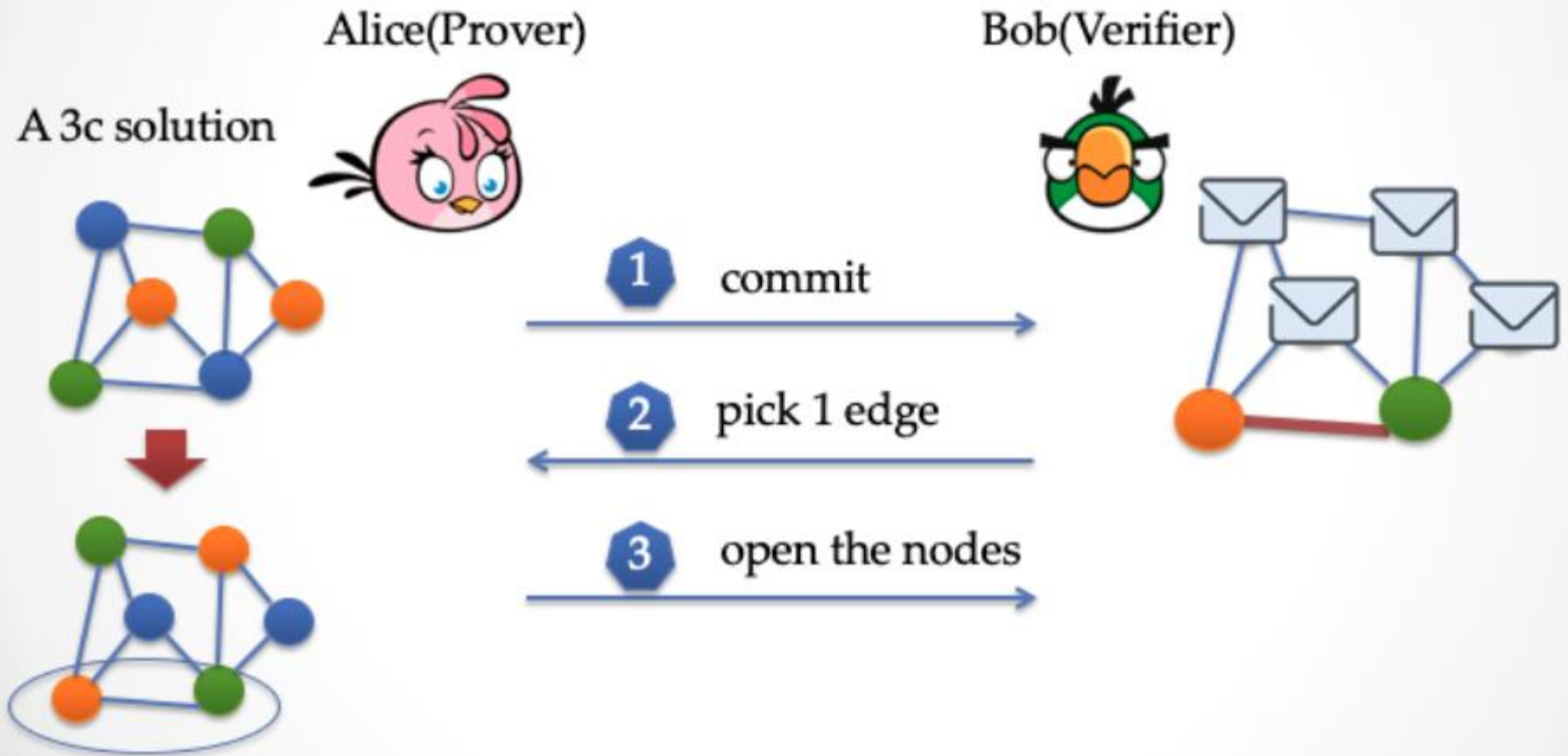
地图三染色问题

- Step 1: Alice 先要对**染过色的图**进行一些「变换」，把颜色做一次大挪移，例如把所有的绿色变成橙色，把所有的蓝色变成绿色，把所有的橙色变成蓝色。这样，Alice 得到一个新的染色答案，这时候她把新图的每一个顶点都用纸片盖上，然后出示给 Bob 看。



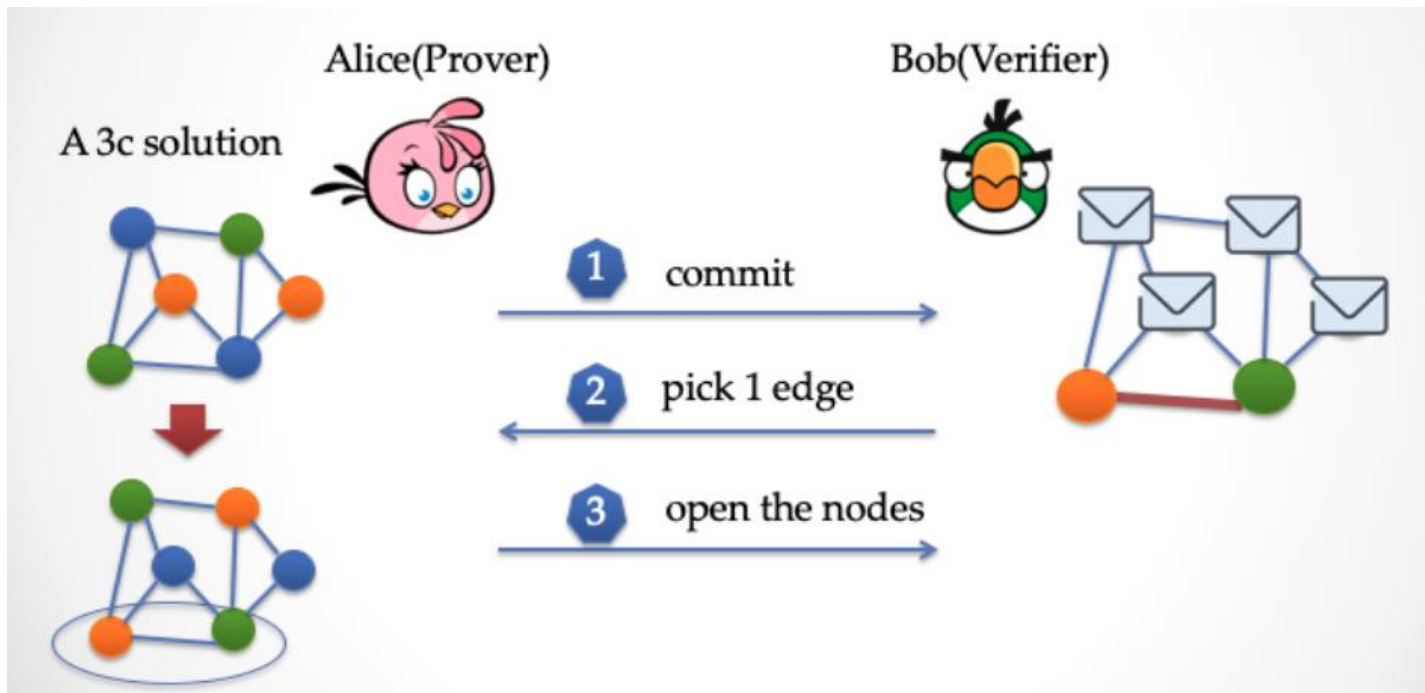
地图三染色问题

- Step 2: Bob 随机挑选一条「边」，注意是随机，不让 Alice 提前预测到的随机值。
- 假设 Bob 挑选的是最下面的一条边，然后告诉 Alice。



地图三染色问题

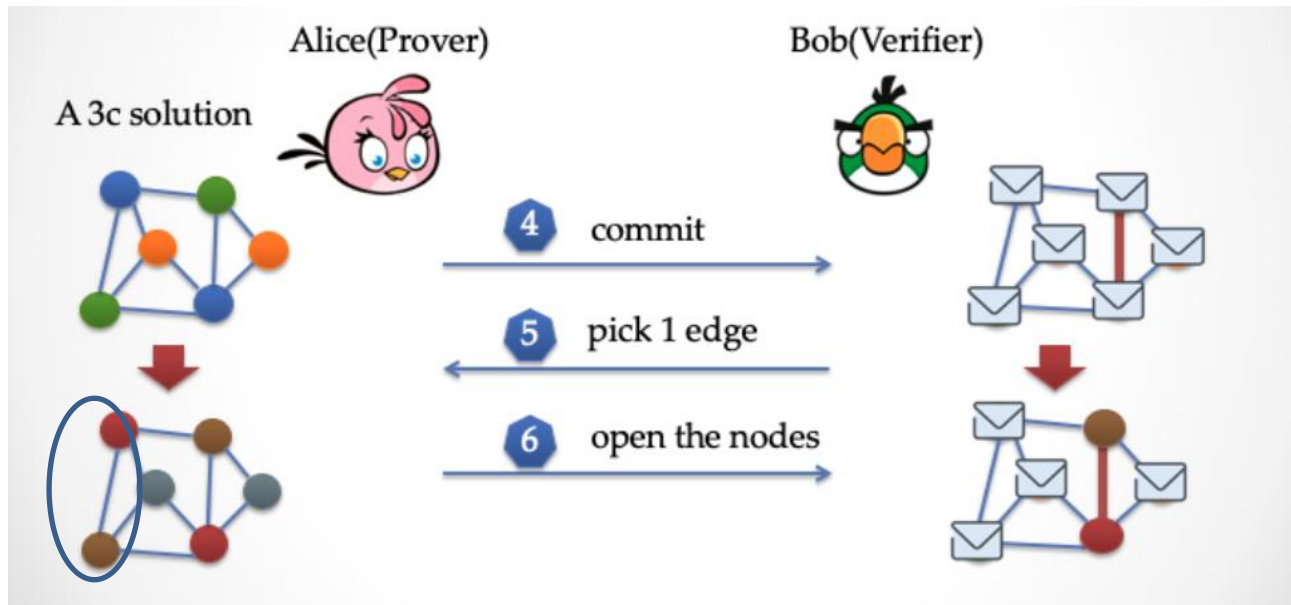
□ Step 3: Alice 揭开这条边两端的纸片，让 Bob 检查，Bob 发现这两个顶点的颜色是不同的，那么 Bob 认为这次检验通过。



这时候，Bob 只看到了图的局部，也许恰好 Alice 蒙对了呢？
没关系，Bob 可以要求 Alice 再来一遍！

证明过程重复n遍

- Step 4-6: Alice 再次把颜色做一次变换，如把蓝色改成紫色，改绿色改成棕色，把橙色改成灰色，然后把所有的顶点盖上纸片。然后 Bob 再挑选一条边，比如像上图一样，选择的是一条竖着的边，然后让 Alice 揭开纸片验证。



如果Bob仍信心不足， 可以要求 Alice 再来一遍。

Alice作弊成功的概率

- 那么经过反复多次重复这三个步骤，可以让“Alice作弊并能成功骗过Bob”这一事件的概率以指数级的方式减小。经过 n 轮之后，Alice作弊成功的概率为

$$\Pr[(G, c) \parallel \text{ThreeColor}(G, c) = 0] < (1 - \frac{1}{|E|})^n$$

其中， $|E|$ 是图中所有边的个数，如果 n 足够大，如 $n=128$ ，这个概率 $\Pr$ 会变得非常非常小，可忽略。

- Bob 每次看到的局部染色情况都是 Alice 变换过后的结果，无论 Bob 看多少次，都不能拼出一个完整的三染色答案出来。实际上，Bob 在这个过程中，虽然获得了很多「信息」，但是却**没有获得真正的「知识」**。

信息 vs. 知识

- 在地图三染色问题的交互证明中，当重复交互很多次之后，Bob 得到了大量的信息，但是这好比 Alice 发给 Bob 一堆随机数一样，Bob 并没有「知道」更多的东西。
- 如果 Bob 在交互过程中获得的「信息」，可以帮助提升 Bob 直接破解 Alice 秘密的能力，那么我们说 Bob 「获得了知识」。

由此可见，知识这个词的定义与 Bob 的计算能力相关，如果信息并不能增加 Bob 的计算能力，那么信息不能被称为「知识」。比如在 Alice 与 Bob 交互过程中，Alice 每次都掷一个硬币，然后告诉 Bob 结果，从信息角度看，Bob 得到的信息只是一个「事件」，然而 Bob 并没有得到任何「知识」，因为 Bob 完全可以自己来掷硬币。



提 纲

CONTENTS



1. 零知识证明概念总揽

2. 一个典型实例

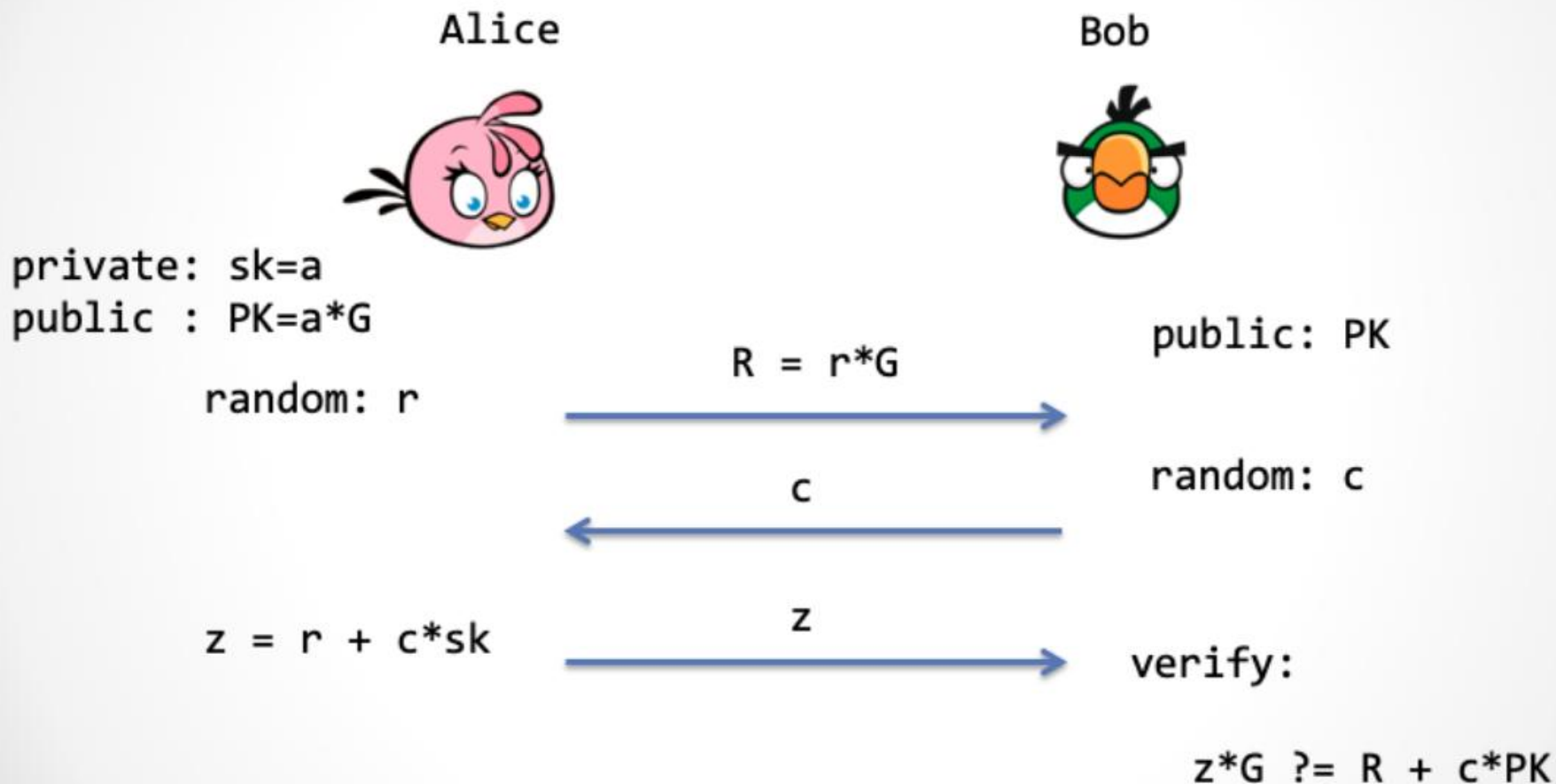
3. Schnorr鉴别协议

4. GQ鉴别协议

5. Schnorr鉴别协议

交互式零知识协议

❑ Schnorr 认证协议, 三轮。Alice向Bob证明拥有私钥sk。



❑ 通过随机数挑战是交互式零知识证明的「信任根基」。

交互式零知识证明的问题

- ❑ 交互式零知识协议只能取信于一个验证者，非交互式零知识证明（NIZK），如果存在，NIZK可以取信于多个验证者，以至所有人。
- ❑ 交互式证明，只能在交互的那个时刻有效；而NIZK将始终有效。
- ❑ 交互式证明需要多轮交互，效率不高，而NIZK不需要双方或多方交互，通信效率高。

非交互式零知识证明（NIZK），如果存在，要比交互式证明强大得多！正好解释了为什么NIZK现今如此流行（如密码协议、隐私计算）。

非交互式零知识协议 (NIZK)

❑ Schnorr 认证协议经Fiat-Shamir变换, 通信由三轮变为一轮。

采用 Hash 函数的方法来把一个交互式的证明系统变成非交互式的方法被称为 Fiat-Shamir 变换, 它由密码学先驱 Amos Fiat 和 Adi Shamir 两人在 1986 年提出。



private: $sk=a$
public : $PK=a*G$
random : r

$R = r*G$
 $c = \text{Hash}(PK, R)$
 $z = r + c*sk$

(R, z)



Bob



public: PK

verify:

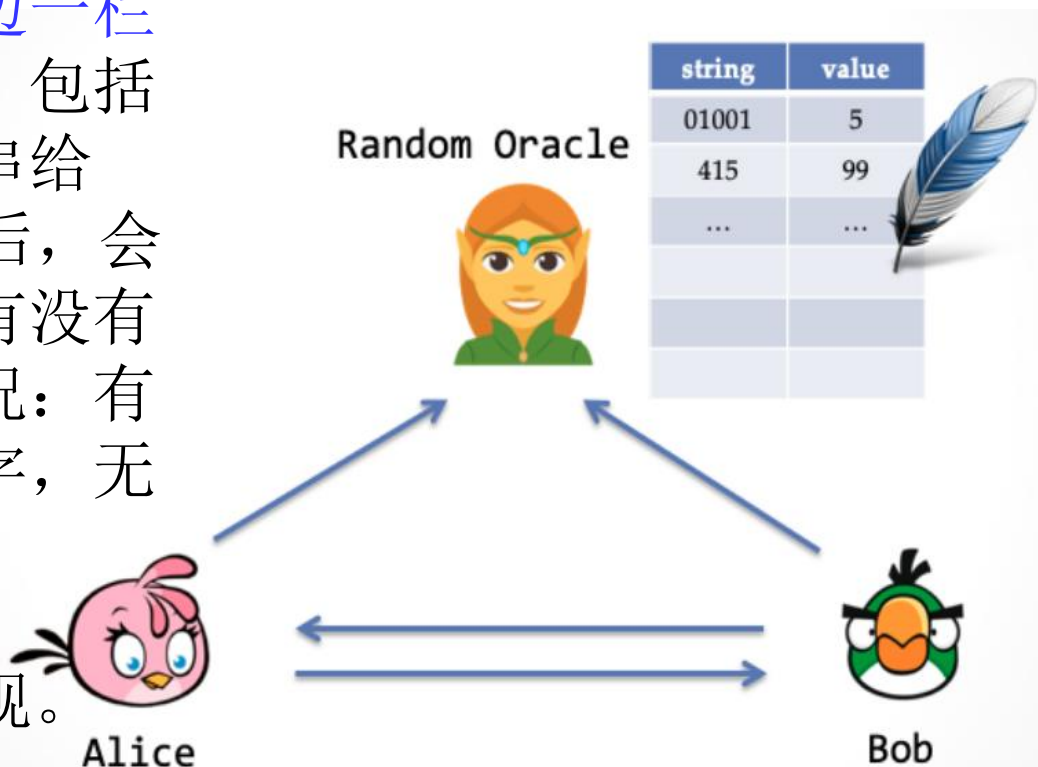
$c = \text{Hash}(PK, R)$
 $z*G \stackrel{?}{=} R + (c*PK)$

随机预言机

□ 前文提到，失去了随机数挑战，似乎失去了零知识证明的「信任根基」。而在非交互式Schnorr认证方案中，Hash函数担负起了「挑战者」的角色，称为随机预言机(ROM)。

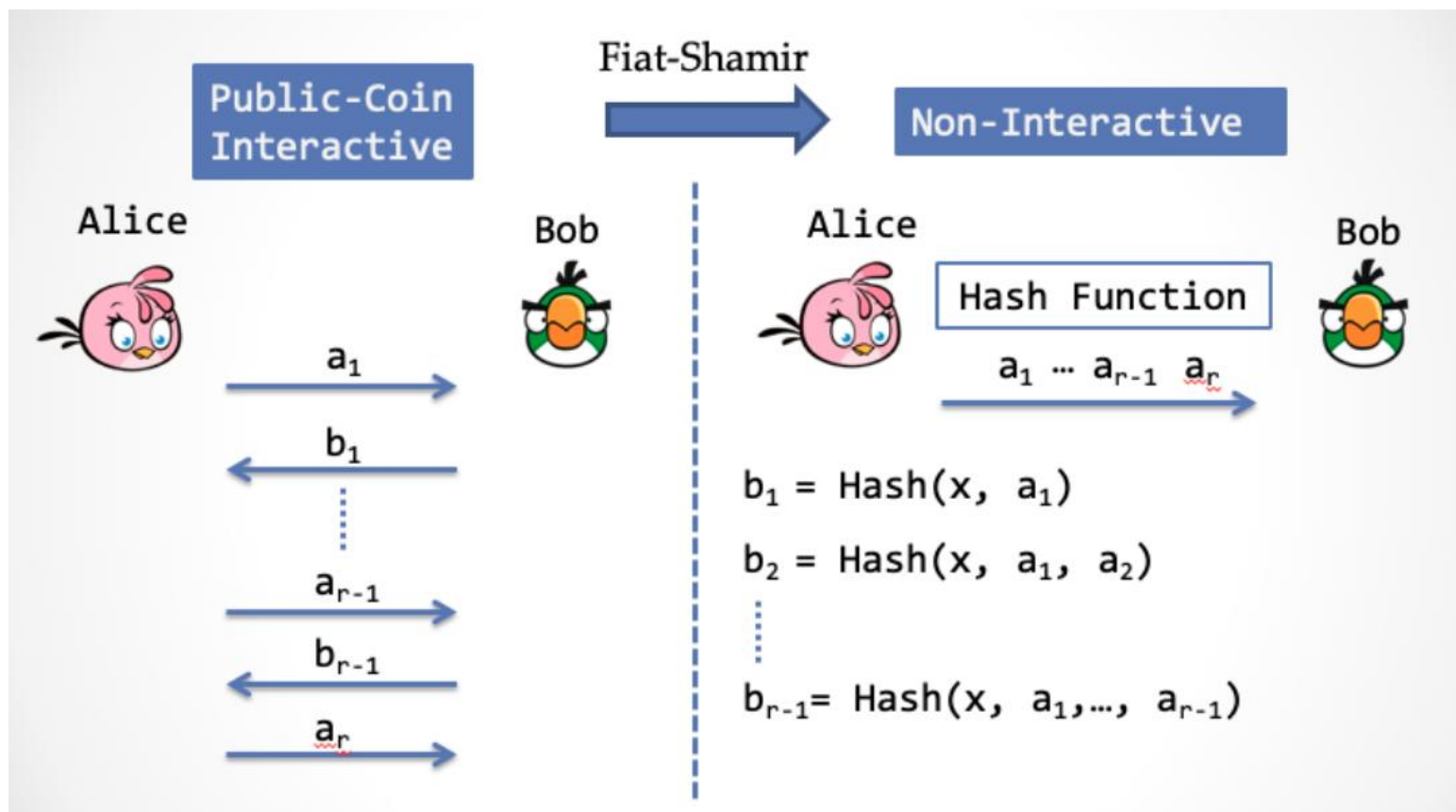
随机预言机ROM本质是一个双栏表格，左边一栏为字符串，右边一栏为数字。任何人，包括你我，包括Alice和Bob，都可以发字符串给ROM。ROM在拿到字符串之后，会查表的左边栏，看看表格里有没有这个字符串，下面分两种情况：有则返回字符串对应的右栏数字，无则随机输出。

ROM一般通过Hash函数来实现。



Fiat-Shamir变换 — 从 Public-Coin 到 NIZK

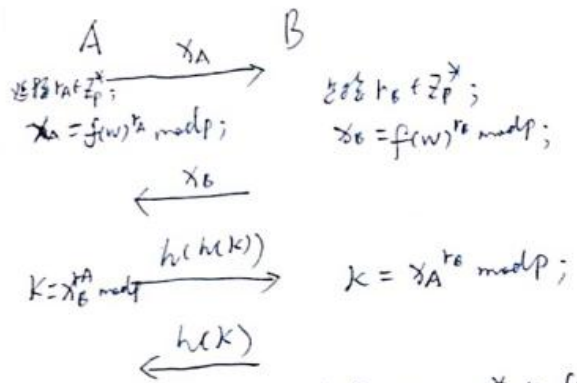
□ 不仅对于 Schnorr 协议，对于任意的「Public-Coin 协议」，都可以用 Fiat-Shamir 变换来把整个协议「压缩」成一步交互，也就是一个非交互式的证明系统，这个变换技巧最早来自于 Amos Fiat 与 Adi Shamir 发表于1986年的美密会论文。



如何通过NIZK向他人证明知道私密 a

1996 Jablon SPEKE

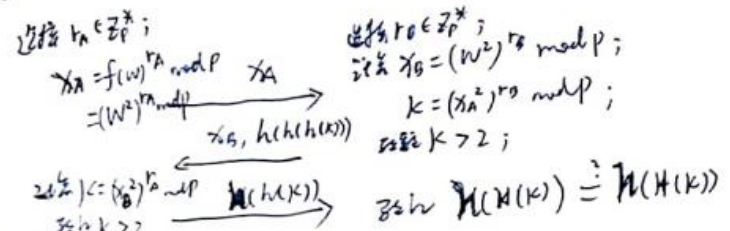
p prime;
 D 集合
 $w \in D$; $||w||$
 $h(\dots)$: hash function
 $f(\dots): D \rightarrow \mathbb{Z}_p^*$



问题: 如何构造一个 $f: D \rightarrow \mathbb{Z}_p^*$ 的 $f(r), t \in D$
 为一个中一个阶较大的元素。

对策: 若 p 为安全素数, 则 $p = 2q + 1$, q 亦为素数。
 故 $f(w) = w^2 \bmod p$ 一定为 p 的 q 阶循环
 群 $\mathbb{Z}_p^*$ 中元素, where $w \neq 0, 1, p-1$.

fully constrained version:

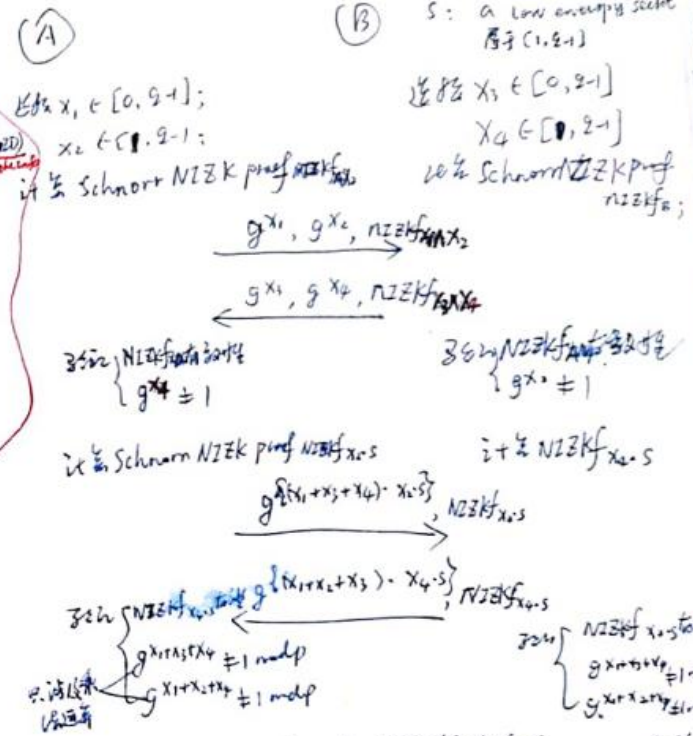
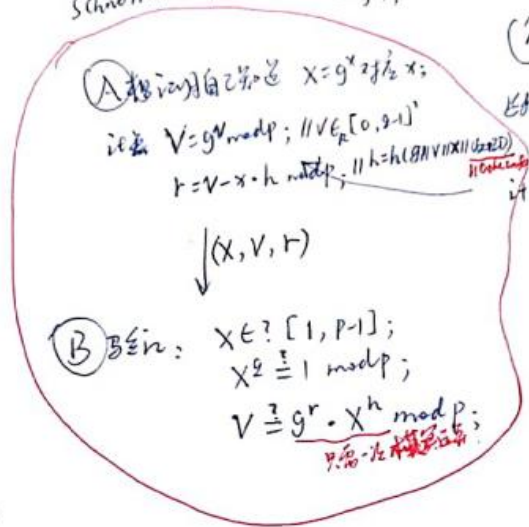


J-PALKE

IETF draft 2013

large
 P. Shoup
 21P-1;
 98 82 82 82

Schnorr NIZK proof of knowledge of x ; Two round version



问题: 如何 find $ic \in \mathbb{Z}_p^*$, 使
 $a = b^i \bmod p$ 成立, 但
 且 $ic = \log a b$ 在 $\mathbb{Z}_p^*$ 中。

对策: 若 $w = a^i, w = a^{j_2} \dots w_m = a^{i_m}$;
 则 $ic = \log a b$ 在 $\mathbb{Z}_p^*$ 中。

$$K = \left(g^{(x_1+x_2+x_3) \cdot x_4 \cdot s} / g^{(x_1 \cdot x_2 \cdot s)} \right)^{x_2}$$

$$= g^{(x_1+x_2) \cdot x_2 \cdot x_4 \cdot s}$$

$$= \left(g^{(x_1+x_2+x_3) \cdot x_2 \cdot s} / g^{x_2 \cdot x_4 \cdot s} \right)^{x_4}$$

Encryption Key $sk = \text{PDF}(K, \text{ENC})$
 MAC Key $Mac = \text{PDF}(K, \text{MAC})$

欢迎各位同学交流指正！



Feige-Fiat-Shamir 鉴别协议 (续)

$$\begin{array}{ccc} A & & B \\ & \xrightarrow{x \equiv r^2 \pmod{n}} & \\ & (e_1, \dots, e_k), e_i \in \{0, 1\} & \\ & \xleftarrow{\hspace{1.5cm}} & \\ & y \equiv r \cdot \prod_{e_j=1} s_j \pmod{n} & \\ & \xrightarrow{\hspace{1.5cm}} & \end{array}$$

- 如果 $z \equiv y^2 \cdot \prod_{e_j=1} v_j^{e_j} \not\equiv 0 \pmod{n}$
并且 $z = x$, 则 B 接受证明; 否则,
 B 拒绝证明。

Feige-Fiat-Shamir 鉴别协议 (续)

$$\begin{array}{ccc} A & & B \\ & \xrightarrow{x \equiv r^2 \pmod{n}} & \\ & (e_1, \dots, e_k), e_i \in \{0, 1\} & \\ & \xleftarrow{\hspace{1.5cm}} & \\ & y \equiv r \cdot \prod_{e_j=1} s_j \pmod{n} & \\ & \xrightarrow{\hspace{1.5cm}} & \end{array}$$

- 如果 $z \equiv y^2 \cdot \prod_{e_j=1} v_j^{e_j} \not\equiv 0 \pmod{n}$
并且 $z = x$, 则 B 接受证明; 否则,
 B 拒绝证明。

3 Feige-Fiat-Shamir 鉴别协议 (续)

- 例子1 (选择小的参数以利于说明)

(1) 信任中心 T 选择素数 $p=683$, $q=811$, 并公布 $n = p \cdot q = 553913$ 。整数 $k=3$ 和 $t=1$ 被定义为安全参数。

(2) 实体 A 做如下步骤。

(2.1) 选择3个随机整数 $s_1=157$, $s_2=43215$, $s_3=4646$ 。

(2.2) 计算 $v_1=112068$, $v_2=338402$, 和 $v_3=429490$ 。

(2.3) 公开密钥是 $(112068, 338402, 429490; 553913)$, 秘密密钥是 $(157, 43215, 4646)$ 。

(3) (3.1) A 选择 $r=1279$, 计算 $x=528015$, 并发送它给 B 。

(3.2) B 发送给 A 一个3比特向量 $(0, 0, 1)$ 。

(3.3) A 计算并发送给 B 数值 $y \equiv r \cdot s_3 \pmod{n} \equiv 403104$ 。

(3.4) B 计算 $z \equiv y^2 \cdot v_3 \pmod{n} \equiv 528015$ 并接受 A 的身份, 这是因为 $z = x$ 和 $z \neq 0$ 。

对Feige-Fiat-Shamir鉴别协议的评述

- (1) 伪造概率。协议**2**可以证明是抵抗选择消息攻击安全的，也就是，如果分解 n 是困难的，最好的攻击也只有 $2^{-k \cdot t}$ 的概率保证冒充成功。
- (2) 安全假设需求。安全依赖于计算未知分解的大合数 n 的模平方根的困难问题。这个问题等价于计算 n 的分解问题。
- (3) 零知识和正确属性。协议在有可信服务器的情况下是对知识的一个零知识证明，这里假定参数 $k = O(\log \log n)$ 和 $t = \Theta(\log n)$ 。

对Feige-Fiat-Shamir鉴别协议的评述

- (4) 参数选择。选择安全参数 k 和 t 满足 $k \cdot t = 20$ 就可以保证冒充成功的概率只有百万分之一，这在现实中对于个人用户防御冒充的鉴别测试已经足够。考虑到计算，存储，和通信的平衡， $1 \leq k \leq 18$ 是适合的选择。具体的参数选择，对于 2^{-20} 的安全： $k = 5$, $t = 4$; 2^{-30} 的安全： $k = 6$, $t = 5$ 。
- (5) 安全平衡。通过平衡安全参数使得仅需要一轮协议执行，可以减少计算和通信开销。乘积 $k \cdot t$ 作为常数，增加 k 意味着减少 t 。

对Feige-Fiat-Shamir鉴别协议的评述

- (6) 修改考虑。

(6.1) 协议2的第(1)步做改变，每个用户选择自己的模， T 仍然需要将每个用户和他们的模联系起来。

(6.2) 如果 A 发送给 B (例如,128比特)一个hash值 $h(x)$ 而不是 x ， B 的验证也做相应修改，那么通信复杂度可以减少。

(6.3) 协议的平行版本，可以让全部 t 轮的3条消息并行执行，这样做仍然是安全的。在交互证明中这种并行执行(相对于串行循环)可以降低错误率(伪造)，但并不增加轮数。

对Feige-Fiat-Shamir鉴别协议的评述

(6.4) 方案可以改造成如下身份基方案。 T 分配一个标识每个实体 A 的身份不同位串 I_A (例如, 名字, 地址, 或其它验证者希望验证的信息)。 A 的公开值 $v_i, 1 \leq i \leq k$, 可以由 T 和其他实体 B 用 $v_i = f(I_A, i)$ 计算出来, 这里 f 是一个适当的公开函数。由于信任中心 T 知道 n 的分解, 就可以计算 v_i 的平方根 s_i 并将其交给 A 。

对Feige-Fiat-Shamir鉴别协议的评述

(6.5) 如下的一般方法可以将一个证据-提问-回答顺序的鉴别协议转变为数字签名方案：将验证者的随机提问 e 用单向hash值 $e = h(x \parallel m)$ 代替，这里是证据 x 与被签名消息 m 的一个连接(h 基本起到一个验证者的作用)。通过这一变换，一个交互鉴别方案就可以变成一个非交互签名方案，提问 e 的比特长度必须适当增加以防止对hash的离线攻击。



提 纲

CONTENTS



1. 零知识证明概念总揽

2. Fiat-Shamir鉴别协议

3. Feige-Fiat-Shamir鉴别协议

4. GQ鉴别协议

5. Schnorr鉴别协议

GQ鉴别协议

- 摘要：证明者 A 通过一个3轮协议向验证者 B 证明自己的身份(通过掌握知识 s_A)。
- (1) 系统参数选择.
 - (1.1) 一个为各方信任的权威 T 负责将公开密钥与用户身份绑定。 T 选择一个秘密的随机RSA型素数 p 和 q 并产生模 $n = p \cdot q$ 。(作为RSA，分解 n 必定不可能。)
 - (1.2) T 定义一个公开指数 $v \geq 3$ ，满足 $(v, \varphi) = 1$ ，这里 $\varphi = (p-1)(q-1)$ ，并计算他的秘密指数 $s \equiv v^{-1} \pmod{\varphi}$ 。
 - (1.3) 所有用户都可以获得系统参数 (v, n) 。(并保证其真实性)

4 GQ鉴别协议(续)

(2) 每个用户参数选择.

(2.1) 每个用户 A 被赋予唯一的一个身份 I_A , 从这个身份值可以计算(冗余身份) $J_A = f(I_A)$, 满足 $1 < J_A < n$, 这里 f 是一个公开的冗余函数。(假定分解 n 困难隐含了 $(J_A, n) = 1$.)

(2.2) T 将秘密(审定合格的数据) $s_A \equiv (J_A)^{-s} \pmod{n}$ 交给 A .

(3) 协议执行. A 通过 t 次执行如下步骤向 B 证明自己的身份;
 B 仅在 t 次执行都成功的情况下接受其身份。

4 GQ鉴别协议(续)

- (3.1) A 选择一个随机整数 r (承诺), $1 \leq r \leq n-1$, 并且计算 (证据) $x \equiv r^v \pmod{n}$ 。
- (3.2) A 发送整数对 (I_A, x) 给 B 。
- (3.3) B 选择并发送一个随机整数 e (提问), $1 \leq e \leq v$, 给 A 。
- (3.4) A 计算并发送 $y \equiv r \cdot s_A^e \pmod{n}$ 给 B (回答)。
- (3.5) B 收到 y 之后, 用 f (见上面) 从 I_A 建立 J_A , 计算 $z \equiv J_A^e \cdot y^v \pmod{n}$, 并且如果 $z = x$ 和 $z \neq 0$, 就接受 A 对其身份的证明。(后一种情况是为了阻止攻击者选择 $r = 0$ 。)

4 GQ鉴别协议 (续)

A

B

$$\xrightarrow{I_A, \quad x \equiv r^v \pmod{n}}$$

$$\xleftarrow{e, \quad \text{这里 } 1 \leq e \leq v}$$

$$\xrightarrow{y \equiv r \cdot s_A^e \pmod{n}}$$

- 如果 $z \equiv J_A^e \cdot y^v \not\equiv 0 \pmod{n}$
并且 $z \equiv x$, 则 *B* 接受证明;
否则, *B* 拒绝证明。

4 GQ鉴别协议(续)

- 例子2(使用小参数并且 $t = 1$)

(1)(1.1) 权威 T 选择素数 $p = 569, q = 739$, 并且计算 $n = p \cdot q = 420491$ 。

(1.2) T 计算 $\phi = (p-1)(q-1) = 419184$, 选择 $v = 54955$, 并且计算 $s \equiv v^{-1} \pmod{\phi} \equiv 233875$ 。

(1.3) 系统参数 $(54955, 420491)$ 让全体用户得到。

(2)(2.1) 假定 A 的冗余身份参数是 $J_A = 34579$ 。

(2.2) T 将审定合格的数据 $s_A \equiv (J_A)^{-s} \pmod{n} \equiv 403154$ 发给 A 。

(3)(3.1) A 选择 $r = 65446$ 并计算 $x \equiv r^v \pmod{n} \equiv 89525$ 。

(3.2) A 发送整数对 $(I_A, 89525)$ 给 B 。

(3.3) B 发送随机提问 $e = 38980$ 给 A 。

(3.4) A 发送 $y \equiv r \cdot s_A^e \pmod{n} \equiv 83551$ 给 B 。

(3.5) B 计算 $z \equiv J_A^e \cdot y^v \pmod{n} \equiv 89525$ 并接受 A 的身份, 这是因为 $z = x$ 和 $z \neq 0$ 。

4 对GQ鉴别协议的评述

- (1) 伪造的概率。在协议3中, v 决定安全等级(比较Fiat-Shamir协议, 这里 $v=2$ 却需要许多轮交互); 一些值如 $v=2^{16}+1$ 有利于有效计算。一个冒充的证明者可以 $1/v$ 的概率成功事先猜测 e (并进一步像验证者一样计算 $x \equiv J_A^e \cdot y^v$) 攻击协议。推荐的 v 的比特长度应该根据攻击者存在的环境而定。
- (2) 需要的安全假设。计算模合整数 n 的 v 次平方根(也就是, 求解RSA问题)是攻击协议的方法; 这并不比分解 n 更困难, 但在不知道 n 的因子情况下通常认为是困难的。

4 对GQ鉴别协议的评述

- (3) 正确属性。在实践中，GQ方案建议 $t=1$ 而 v 是一个 k 比特素数。对于一般参数 (n, v, t) ，伪造的概率是 v^{-t} 。如果 v 是一个常数，技术上对于正确属性的要求是， t 必须渐进增加快于 $\log \log n$ 。
- (4) 零知识属性。与正确性相反，对于GQ方案的零知识属性要求 $t \cdot v = O((\log n)^c)$ ，这里 c 是一个整数，考虑 t 的渐进上限：对于 v 为常数的情况， t 必须不大于 $\log n$ 的多项式。
- (5) 使用冗余函数的目的是阻止攻击者计算出对应虚假身份的错误审定合格的数据。



提 纲

CONTENTS



1. 零知识证明概念总揽

2. Fiat-Shamir鉴别协议

3. Feige-Fiat-Shamir鉴别协议

4. GQ鉴别协议

5. Schnorr鉴别协议

Schnorr 身份鉴别

- 基本思想：证明者A以一个时变的方式(根据验证者临时的提问 e)来证明其掌握秘密知识 a (而不给出 a)。

证书 $cert_A = (I_A, v = \beta^{-a} \pmod{p}, S_T(I_A, v))$ 将 I_A 和 v 绑定。

$$\begin{array}{ccc} A & cert_A, x \equiv \beta^r \pmod{p} & B \\ \hline & e // \text{这里 } 1 \leq e \leq 2^t < q & \\ \hline & y \equiv a \cdot e + r \pmod{q} & \\ \hline \end{array}$$

如果 $z \equiv \beta^y \cdot v^e \equiv x \pmod{p}$ ，则 B 接受证明；
否则， B 拒绝证明。

Schnorr 身份鉴别

□ 协议简述：证明者 A 通过一个3轮协议向验证者 B 证明自己的身份：自己知道公钥对应的私钥。

(1) 系统参数选择.

(1.1) 选择一个适当的素数 p 满足 $p-1$ 可以被另一个素数 q 整除。(保证模 p 的离散对数在计算上不可能。)

(1.2) 选择一个乘法阶为 q 的元 $\beta, 1 \leq \beta \leq p-1$ 。

(1.3) 每一方得到一份真实的系统参数(p, q, β)和信任中心 T 的验证公开密钥的函数，它可以验证 T 对消息 m 的签名 $S_T(m)$ 。(S_T 涉及在签名之前的一个适当的公开hash函数和任意一个签名机制。)

5 Schnorr 身份鉴别 (续)

(1.4) 选择一个安全参数 t (例如, $t \geq 40$), $2^t < q$ (定义一个安全等级 2^t)。

(2) 每个用户参数选择.

(2.1) 每个实体 A 选择一个唯一身份 I_A 。

(2.2) A 选择一个秘密密钥 a , $0 \leq a \leq q-1$, 并计算 $v \equiv \beta^{-a} \pmod{p}$ 。

(2.3) A 向 T 通过传统方式(例如, 出示护照)验证自己的身份, 接着将真实的 v 传递给 T , 最后得到一个由 T 颁发的证书 $cert_A = (I_A, v, S_T(I_A, v))$ 将 I_A 和 v 绑定。

5 Schnorr 身份鉴别（续）

(3) 协议执行. A 按如下步骤向 B 验证自己的身份。

(3.1) A 选择一个随机数 r (承诺), $1 \leq r \leq q-1$, 计算(证据) $x \equiv \beta^r \pmod{p}$, 并发送 $(cert_A, x)$ 给 B 。

(3.2) B 通过 T 在证书 $cert_A$ 中的签名验证 A 的公开密钥 v 的真实性, 接着发送一个(从未使用过的)随机数 e (提问), $1 \leq e \leq 2^t$, 给 A 。

(3.3) A 检查 $1 \leq e \leq 2^t$ 并发送(回答) $y \equiv a \cdot e + r \pmod{q}$ 给 B 。

(3.4) B 计算 $z \equiv \beta^y \cdot v^e \pmod{p}$, 如果 $z = x$, 接受 A 的身份。

Schnorr 身份鉴别: Toy example

□ 例子3 (使用小参数是为了便于说明)

(1)(1.1) 选择素数 $p = 48731$, 这里 $p - 1$ 可以被素数 $q = 443$ 整除。

(1.2) 一个模48731的生成元是 $\alpha = 6$; β 可以通过计算 $\alpha^{(p-1)/q} \pmod{p} \equiv 11444$ 得到。

(1.3) 系统参数是 $(48731, 443, 11444)$ 。

(1.4) 选择参数 $t = 8$ 。

(2) A 选择一个秘密密钥 $a = 357$ 并计算 $v \equiv \beta^{-a} \pmod{p} \equiv 7355$ 。

(3)(3.1) A 选择 $r = 274$ 并发送 $x \equiv \beta^r \pmod{p} \equiv 37123$ 给 B 。

(3.2) B 发送随机提问 $e = 129$ 给 A 。

(3.3) A 发送数字 $y \equiv a \cdot e + r \pmod{q} \equiv 255$ 给 B 。

(3.4) B 计算 $z \equiv \beta^y \cdot v^e \pmod{p} \equiv 37123$ 并接受 A 的身份, 由于 $z = x$ 。

对Schnorr身份鉴别的点评

- (1) 伪造概率。在协议4中， t 必须足够大使得正确猜测出提问 e 的概率 2^{-t} 可以忽略； $t = 40, q \geq 2^{2t} = 2^{80}$ 是最初推荐的参数，回答可以在一秒钟完成，略大的 q 会破坏时间-存储平衡，目前推荐 $q \geq 2^{160}$ 阻止其它可能的离线离散对数攻击。
- (2) 正确属性。我们可以看到协议是一个对知识 a 的证明，也就是，任何可以成功完成协议的 A 都应该确实有能力计算知识 a 。简要说来，协议没有暴露任何关于 a 的有用信息，因为 x 是一个随机数， y 被随机数 r 给搅乱。

对Schnorr身份鉴别的点评（2）

- (3) 零知识属性。对于大的 e ，协议不具有零知识属性，因为通过交互， B 得到了方程 $x \equiv \beta^y \cdot v^e \pmod{p}$ 的解 (x, y, e) ，这是 B 自己所不能计算的(例如，如果 e 是根据 x 选择)。
- (4) 传输带宽。协议所要传输的数据开销可以通过传输预先定义的 x 的 t 比特(例如，最后 t 比特)而不是全部来缩减，之后 B 也仅将这 t 比特与 z 对应的比特相比较。
- (5) 离线计算。Schnorr鉴别的一个优势在于对于证明者仅需要在线计算一个模乘法，这里假定模幂可以预先离线计算。

J-PAKE: 基于NIZK的PAKE

Public information: $G, g, p, \sigma \xleftarrow{R} \text{Setup}(1^\kappa), s \xleftarrow{R} \{0, 1\}^t$

Secret information: $\text{pw} \in \mathbb{Z}_p, \text{pw} \neq 0$

Client A

Server B

$$x_1, x_2 \xleftarrow{R} \mathbb{Z}_p$$

$$X_1 \leftarrow g^{x_1}$$

$$X_2 \leftarrow g^{x_2}$$

$$\pi_1 \xleftarrow{R} \text{NIZK}((X_1, g), x_1, A)$$

$$\pi_2 \xleftarrow{R} \text{NIZK}((X_2, g), x_2, A)$$

$$x_3, x_4 \xleftarrow{R} \mathbb{Z}_p$$

$$X_3 \leftarrow g^{x_3}$$

$$X_4 \leftarrow g^{x_4}$$

$$\pi_3 \xleftarrow{R} \text{NIZK}((X_3, g), x_3, B)$$

$$\pi_4 \xleftarrow{R} \text{NIZK}((X_4, g), x_4, B)$$

$$\xrightarrow{\langle A, X_1, X_2, \pi_1, \pi_2 \rangle}$$

$$\xleftarrow{\langle B, X_3, X_4, \pi_3, \pi_4 \rangle}$$

Abort if $X_4 = 1$

Abort if $\text{VK}((X_3, g), \pi_3, B)$ fails

Abort if $\text{VK}((X_4, g), \pi_4, B)$ fails

$$\alpha \leftarrow (X_1 X_3 X_4)^{x_2 \text{pw}}$$

$$\pi_\alpha \xleftarrow{R} \text{NIZK}((\alpha, X_1 X_3 X_4), x_2 \text{pw}, A)$$

Abort if $X_2 = 1$

Abort if $\text{VK}((X_1, g), \pi_1, A)$ fails

Abort if $\text{VK}((X_2, g), \pi_2, A)$ fails

$$\beta \leftarrow (X_1 X_2 X_3)^{x_4 \text{pw}}$$

$$\pi_\beta \xleftarrow{R} \text{NIZK}((\beta, X_1 X_2 X_3), x_4 \text{pw}, B)$$

$$\xrightarrow{\langle \alpha, \pi_\alpha \rangle}$$

$$\xleftarrow{\langle \beta, \pi_\beta \rangle}$$

Abort if $\text{VK}((\alpha, X_1 X_3 X_4), \pi_\alpha, A)$ fails

$$K \leftarrow (\beta X_4^{-x_2 \text{pw}})^{x_2}$$

$$\text{sk} \leftarrow \text{rExt}(s, K)$$

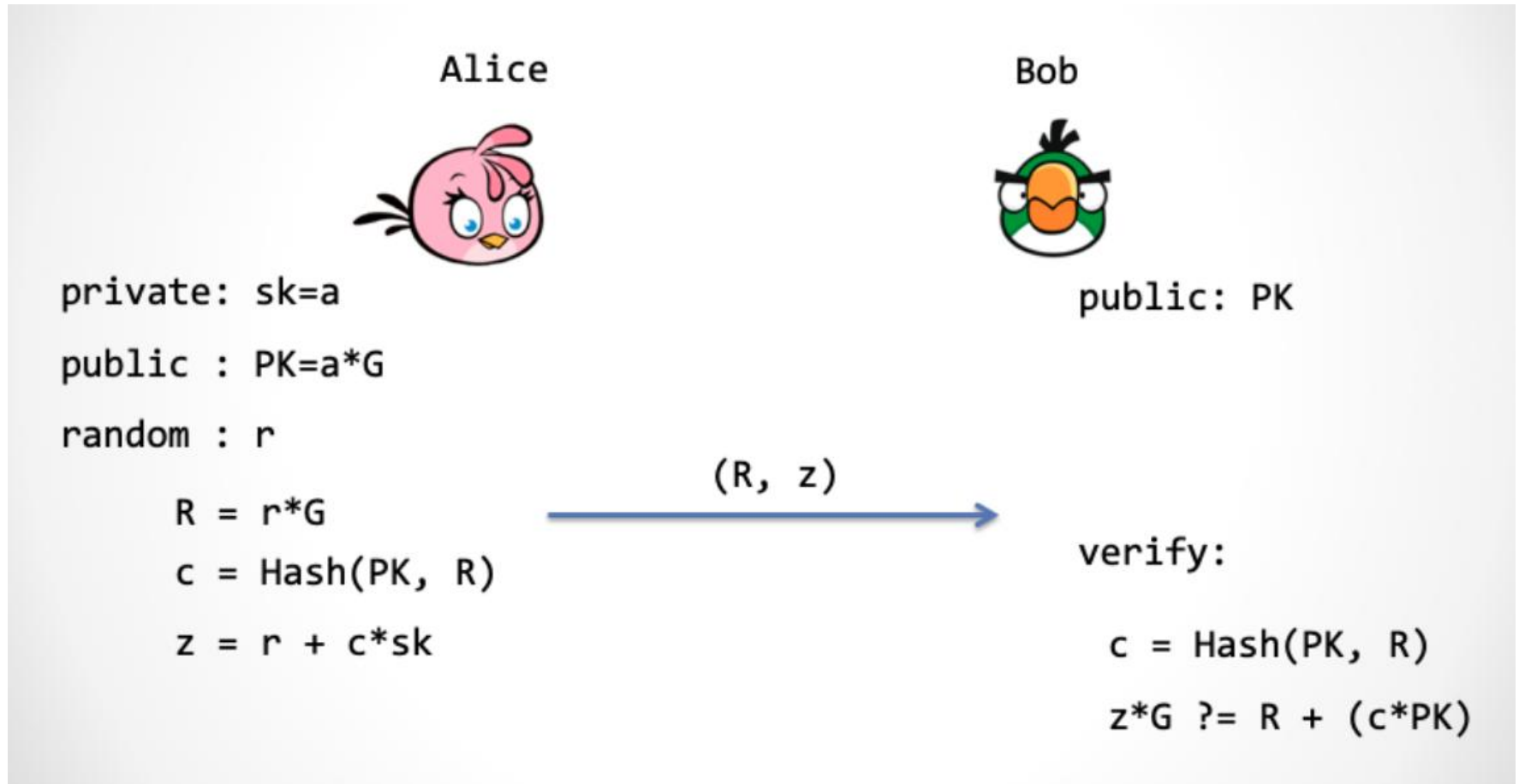
Abort if $\text{VK}((\beta, X_1 X_2 X_3), \pi_\beta, B)$ fails

$$K \leftarrow (\alpha X_2^{-x_4 \text{pw}})^{x_4}$$

$$\text{sk} \leftarrow \text{rExt}(s, K)$$

如何通过NIZK向他人证明知道私密 a

□ 典型工具：Schnorr 认证协议经Fiat-Shamir变换为NIZK



欢迎各位同学交流指正！

